

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO3: *Examine cryptographic hash algorithms, digital signature schemes, and assess Kerberos and X.509 authentication frameworks for ensuring integrity, authentication, and non-repudiation.* CO (BL4 , BL5)

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A CASE STUDY

Code of Conduct:

I ____DOMA SAKETH-192525018____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Annexure A

4.A secure communication system uses a simple hash function to verify message integrity, but attackers are able to modify messages without detection. Analyze why this approach fails and propose a solution using HMAC to improve message authentication.

4. Analysis of Simple Hash Failure and HMAC-Based Solution

1. Understanding of the Case

A secure communication system uses a simple hash function to verify message integrity. However, attackers can modify messages without detection. The main reason is that a normal hash function does not contain any secret information. Anyone who modifies the message can calculate a new hash for the modified message.

For example:

Original message:

Transfer ₹10,000 to Account A

Hash:

$H(\text{Transfer ₹10,000 to Account A})$

An attacker changes the message to:

Transfer ₹50,000 to Account B

The attacker can also calculate a new hash for the modified message. The receiver compares the modified message with the attacker's new hash and may consider it valid.

Thus, a simple hash provides **integrity checking but does not provide authentication**.

2. Application of HMAC

The solution is to use **HMAC (Hash-based Message Authentication Code)**. HMAC combines a cryptographic hash function with a **shared secret key**.

The process is:

1. The sender and receiver share a secret key **K**.

2. The sender calculates:

$$\text{HMAC} = \text{HMAC}(\mathbf{K}, \text{Message})$$

3. The sender sends the message and HMAC to the receiver.

4. The receiver uses the same secret key to calculate an HMAC for the received message.

5. The receiver compares the two HMAC values.

6. If they match, the message is considered authentic and unchanged.

7. If they do not match, the message is rejected.

3. Analysis

HMAC prevents the attacker from generating a valid authentication code because the attacker does not know the secret key. Even if the attacker modifies the message and calculates a normal hash, that hash will not match the correct HMAC.

Therefore, HMAC provides:

- **Message integrity** – detects unauthorized modification.
- **Message authentication** – verifies that the message was generated by someone possessing the shared secret key.
- **Protection against tampering** – modified messages are rejected.
- **Better security** than an unkeyed hash.

A suitable implementation is **HMAC-SHA-256**, where SHA-256 is used as the underlying hash function.

4. Proposed Solution

The communication system should replace the simple hash mechanism with **HMAC-SHA-256**.

Sender:

Message + Secret Key $\rightarrow$ HMAC-SHA-256 $\rightarrow$ HMAC

Transmission:

Message + HMAC $\rightarrow$ Receiver

Receiver:

Received Message + Secret Key $\rightarrow$ HMAC-SHA-256 $\rightarrow$ New HMAC

New HMAC = Received HMAC $\rightarrow$ Accept

New HMAC $\neq$ Received HMAC $\rightarrow$ Reject

5. Conclusion

The existing system fails because a simple hash is publicly computable and therefore cannot authenticate the sender. An attacker can modify both the message and its hash. Using **HMAC with a secret key** solves this weakness by providing both message integrity and authentication. Hence, HMAC-SHA-256 is a more secure and practical solution for the communication system.

6. An e-commerce application uses a symmetric key encryption system to protect customer payment information. After several employees leave the organization, the company discovers that former employees may still have access to encryption keys. Analyze the key management problems in the system and propose a secure key generation, distribution, storage, and revocation mechanism.

6. Analysis of RSA Limitations and Hybrid RSA-AES Solution

1. Understanding of the Case

A healthcare organization uses RSA encryption to protect sensitive patient records transmitted between hospitals. However, performance problems occur when encrypting large files.

RSA is an **asymmetric encryption algorithm** that uses a public key for encryption and a private key for decryption. Although RSA provides strong security, it is computationally expensive and significantly slower than symmetric encryption algorithms such as AES.

Large healthcare files such as medical reports, X-rays, CT scans, MRI images, and patient databases may contain a large amount of data. Encrypting these files directly with RSA results in:

- High computational overhead
- Increased encryption and decryption time
- Greater CPU and memory usage
- Poor performance for large files
- RSA data-size limitations due to its key and padding structure

Therefore, RSA is not suitable for directly encrypting large amounts of data.

2. Application of Concepts

A better approach is to combine **RSA and AES**.

- **AES** is used for encrypting the actual large patient file.
- **RSA** is used to securely encrypt and exchange the AES session key.

This is called **hybrid encryption**.

3. Proposed Hybrid Encryption Process

Sender Hospital

Step 1: Generate a random AES session key.

Step 2: Encrypt the large patient record using AES:

Patient Record + AES Key $\rightarrow$ AES Encryption $\rightarrow$ Ciphertext

Step 3: Encrypt the small AES session key using the receiver hospital's RSA public key:

AES Key + RSA Public Key $\rightarrow$ RSA Encryption $\rightarrow$ Encrypted AES Key

Step 4: Send both:

Encrypted Patient Record + Encrypted AES Key

Receiver Hospital

Step 5: Use the RSA private key to decrypt the encrypted AES key:

Encrypted AES Key + RSA Private Key $\rightarrow$ AES Key

Step 6: Use the recovered AES key to decrypt the patient record:

Encrypted Patient Record + AES Key $\rightarrow$ Original Patient Record

4. Analysis of the Hybrid Approach

The hybrid approach combines the strengths of both algorithms.

Feature	RSA	AES
Type	Asymmetric	Symmetric
Speed	Relatively slow	Very fast
Large-file encryption	Inefficient	Efficient
Key exchange	Excellent	Requires secure key sharing
Main purpose	Encrypt AES key	Encrypt patient data

RSA does not need to encrypt the entire file. It only encrypts the small AES session key. AES performs the computationally intensive encryption of the large healthcare data.

This significantly reduces processing time and computational overhead while maintaining strong security.

5. Security Improvements

The system should use a modern authenticated AES mode such as **AES-GCM**, which provides both confidentiality and integrity.

The RSA component should use a secure padding scheme such as **RSA-OAEP** rather than textbook RSA.

The overall process becomes:

Patient Data → AES-GCM → Encrypted Data

AES Session Key → RSA-OAEP → Encrypted AES Key

Encrypted Data + Encrypted AES Key → Secure Transmission

6. Conclusion

Using RSA alone for large healthcare files is inefficient because RSA is computationally expensive and designed primarily for small amounts of data and secure key exchange. A **hybrid RSA-AES system** provides a more efficient and secure solution. AES rapidly encrypts large patient records, while RSA securely protects the AES session key. Using **AES-GCM with RSA-OAEP** further improves confidentiality, integrity, and secure key management.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Case	25	Thorough understanding; clearly identifies all key issues	Good understanding with most issues identified	Basic understanding; some issues missed	Poor understanding; problem not identified correctly
Application of Concepts	25	Effectively applies relevant concepts to analyze the case deeply	Applies appropriate concepts with minor gaps	Limited application of concepts	Fails to apply relevant concepts
Analysis	20	In-depth analysis with strong reasoning and insights	Good analysis with logical reasoning	Basic analysis with limited depth	Weak or no analysis; lacks reasoning
Solution Design	20	Innovative, feasible solutions with strong justification	Logical solutions with adequate justification	Basic solutions with weak justification	Incorrect or no solution provided
Clarity	10	Clear, wellstructured, and easy to understand	Organized and understandable presentation	Limited clarity and structure	Poor clarity; difficult to understand